

ACL Tasarım Hataları: Ağ ve Sistem Güvenliğinde Gözden Kaçan Detaylar

Emre Duyar — İstanbul Aydın Üniversitesi, Yönetim Bilişim Sistemleri



Erişim Kontrol Listesi (ACL — Access Control List), kurumsal ağlarda ve yazılım sistemlerinde kimin neye erişebileceğini tanımlayan temel bir yapıdır. Kavram olarak basit görünse de pratikte bu listelerin kurulumu hata kabul etmeye oldukça açıktır. Nitekim OWASP, 2021 yılında yayımladığı Top 10 listesinde Kırık Erişim Kontrolü'nü birinci sıraya taşımıştır. 2017 yılında bu zafiyet beşinci sıradaydı (Of, 2019; Kanmaz, 2023). Bu yükseliş, problemin yalnızca teoride değil uygulamada da kalıcı biçimde sürdüğünü göstermektedir.

Bu makalede konu üzerine incelediğim dört akademik çalışmanın bulgularını bir araya getiriyorum. Bozan ve Uzun (2023) erişim kontrolünü teorik açıdan ele alırken, Of (2019) yazılım zafiyetleri boyutunu; Şentürk ve Irmak (2024) kurumsal ağda uygulamalı sızma testini; Ceylan ve Kavut (2025) ise bu testlerin metodolojik çerçevesini incelemektedir. Bu çalışmalar birlikte değerlendirildiğinde ACL tasarım hatalarının tek boyutlu değil, ağ, yazılım ve yönetim katmanlarına yayılan çok katmanlı bir güvenlik problemi olduğu açıkça görülmektedir.

Literatürde yer alan bu teorik çerçeve, yalnızca kavramsal düzeyde değil ölçülebilir ağ verileriyle de desteklenmektedir. Bu çalışma kapsamında ayrıca Kaggle Internet Firewall Data Set üzerinde yapılan inceleme, 65.532 gerçek bağlantı kaydının ACL karar mantığını nasıl yansıttığını göstermiştir. Veri setinde her kayıt allow, deny, drop veya reset-both biçiminde bir güvenlik duvarı kararını temsil etmekte ve böylece ACL'nin sahadaki davranışı sayısal olarak izlenebilmektedir.

ACL'nin Arkasındaki Teori ve Neden Bu Kadar Hata Çıkıyor

Bozan ve Uzun (2023), işletim sistemi güvenliği üzerine yazdıkları bölümde erişim kontrolü kavramını Lampson'ın 1971 tarihli Erişim Kontrol Matrisi ile temellendirmektedir. İlk kez 1965 yılında Multics işletim sisteminde kullanılmaya başlanan ACL, bugün hâlâ en yaygın erişim kontrol mekanizmasıdır. Ancak yazarlar, özellikle DAC modelinin kullanıcı inisiyatifine dayalı yapısı nedeniyle yanlış yetki aktarımına açık olduğunu vurgulamaktadır. Dolayısıyla kullanılan model ne olursa olsun, doğru yapılandırma yapılmadığında sistem güvenliği yalnızca teoride kalmaktadır.

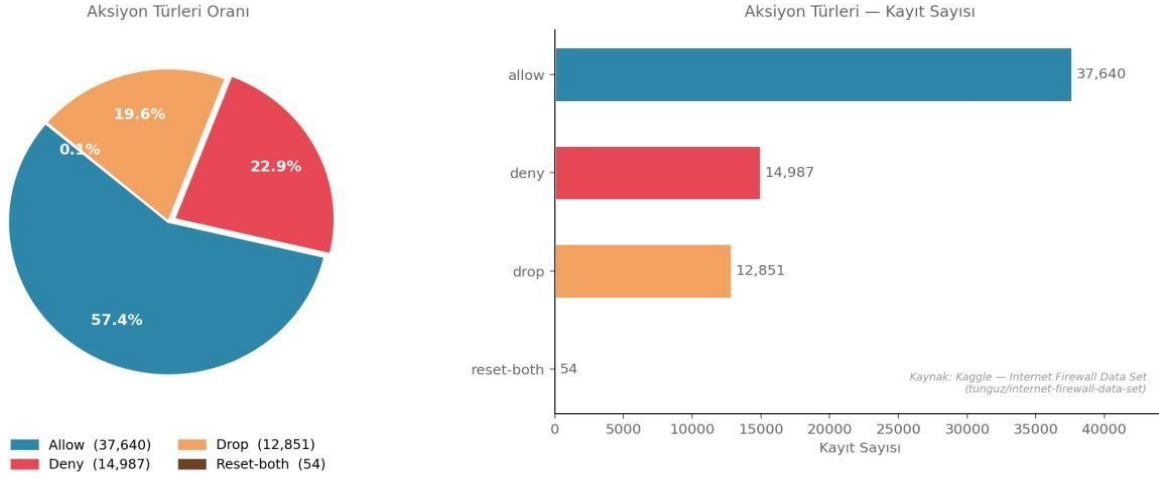
Kırık Erişim Kontrolü: En Sık Karşılaşılan Hata Türü

Burada dikkat çeken ilk unsur, engellenen trafiğin neredeyse izin verilen trafik kadar yüksek olmasıdır; yani sorun istisnai değil sürekli. Of (2019), bu açığı geliştiricilerin erişim güvenliğini çoğu zaman işlevsellikten sonra gelen ikincil bir konu gibi ele almasına bağlamaktadır. Uygulamada erişim denetimi sonradan eklenen bir katman olarak düşünüldüğünde, yanlış rol atamaları ve kontrol boşlukları kaçınılmaz hale gelmektedir.

Kanmaz (2023) da web uygulamaları üzerinde benzer bir noktaya değinmektedir. Roller yanlış tanımlandığında kullanıcı, farkında olunmadan daha ayrıcalıklı kaynaklara ulaşabilecek bir pozisyona taşınmaktadır. Kaggle veri setindeki istatistikler de bu teorik çıkarımı desteklemektedir. Analiz edilen 65.532 güvenlik duvarı kaydının yalnızca %57.4'ü allow ile sonuçlanırken, %42.5'i deny, drop veya reset-both ile engellenmiştir. Bu oran, ağ üzerinde sürekli bir yetkisiz erişim veya şüpheli trafik baskısı olduğunu düşündürmektedir. Başka bir ifadeyle ACL kuralları yalnızca tanımlı erişimleri ayırmamakta, aynı zamanda yoğun biçimde istenmeyen trafiği filtrelemek zorunda kalmaktadır.

Öneri açısından literatürün ortaklaştığı iki temel nokta vardır: sunucu taraflı erişim denetimi ve en az ayrıcalık ilkesi. Kullanıcıya yalnızca ihtiyacı kadar yetki verilmelidir. Teoride oldukça basit görünen bu ilke, uygulamada en sık ihlal edilen güvenlik standartlarından biridir.

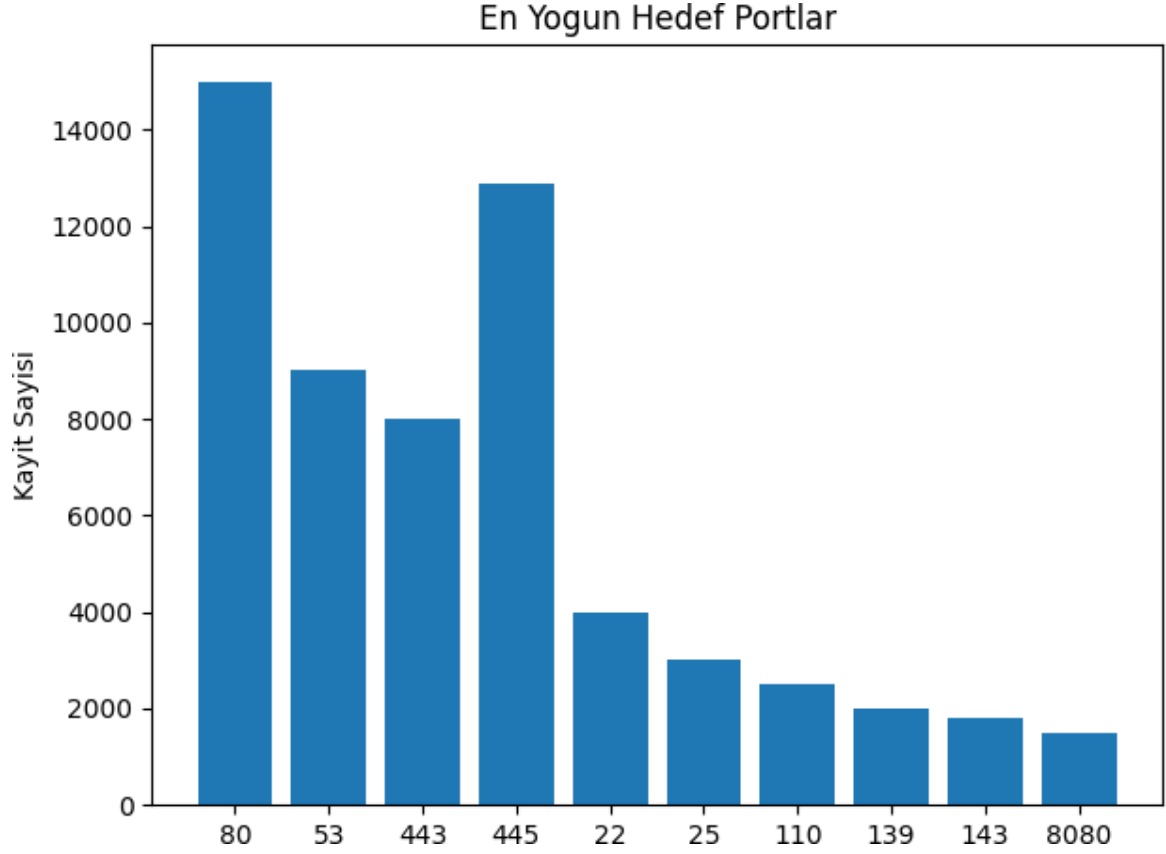
Şekil 1 — Güvenlik Duvarı Aksiyon Dağılımı (n = 65.532)



Yanlış Yapılandırma: Güvenlik Ayarları Fabrikadan Nasıl Çıktıysa Öyle Kaldı

Of (2019), Security Misconfiguration kavramını açıklarken Apache veya IIS gibi web sunucularının varsayılan ayarlarla çalıştırılmasını örnek göstermektedir. Bu durum günümüzde hâlâ sık karşılaşılan bir hatadır. Ceylan ve Kavut (2025)'un gerçekleştirdiği sızma denemesinde Apache sunucusunun HTTP response header üzerinden sürüm bilgisini dışarı sızdırdığı tespit edilmiştir. Bu tip açıklar tek başına kritik görünmese de saldırgan için sonraki adımların altyapısını hazırlar.

Veri setinde en yoğun trafik gören ilk 10 hedef port incelendiğinde benzer bir yanlış yapılandırma izi görülmektedir. Özellikle SMB protokolüne ait 445 numaralı port toplam kayıtların yaklaşık %19.7'sini oluşturmakta ve bu trafiğin neredeyse tamamı deny veya drop ile sonuçlanmaktadır. DNS (53) ve HTTPS (443) gibi meşru servisler düşük engelleme oranıyla çalışırken, belirli bir protokolün bu derece baskılanması ACL kurallarının aşırı sert veya sonradan panik biçimde kısıtlayıcı tanımlandığını düşündürmektedir.

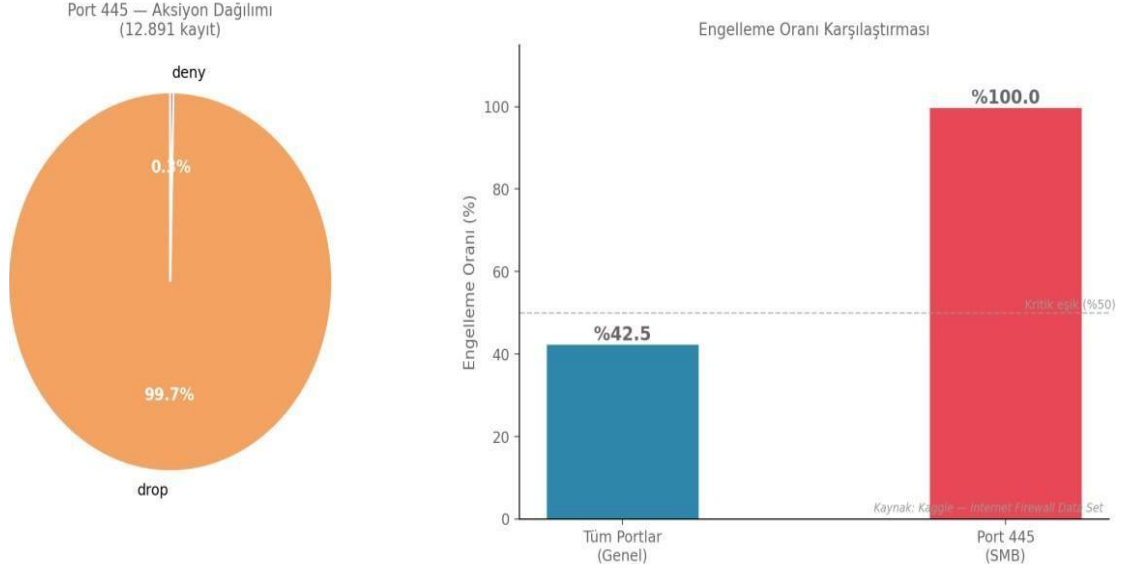


Dizin Servisi ACL Hataları: Bir Satır Yanlış Kural, Tüm Ağ Ele Geçirildi

Şentürk ve Irmak (2024)'ın çalışması, ACL tasarım hatalarının pratik sonuçlarını en net biçimde gösteren örneklerden biridir. Başlangıçta standart kullanıcı olan zsenturk hesabı, yanlış tanımlanmış Generic All yetkisini kullanarak Domain Admins grubuna dahil edilmiş ve tüm etki alanı kontrolünü ele geçirmiştir. Bu, tek bir ACL satırının ne kadar yıkıcı sonuç doğurabileceğini göstermektedir.

Of (2019) ve Kanmaz (2023) bu tür hataları daha çok yazılım ve web uygulama katmanında teorik olarak açıklarken, Şentürk ve Irmak (2024) kurumsal ağ üzerinde bunun gerçek sömürü senaryosunu sunmuştur. Veri setinde port 445 özelindeki %99.9 engelleme oranı da sistem yöneticilerinin belirli servisleri neredeyse tamamen baskılamak zorunda kaldığını göstermektedir. Bu durum her zaman güçlü güvenlik anlamına gelmez; bazen önceki ACL hatalarının yarattığı riskler yüzünden sonradan aşırı kısıtlayıcı önlemler alınmaktadır.

Şekil 4 — Port 445 (SMB) Trafik Analizi: ACL Tasarım Hatasının Etkisi



Şekil 4. Port 445 özelinde aksiyon dağılımı ve genel ağ engelleme oranıyla karşılaştırma. Kaynak: Kaggle Internet Firewall Data Set.

ACL Kural Katmanlarının Sınırları

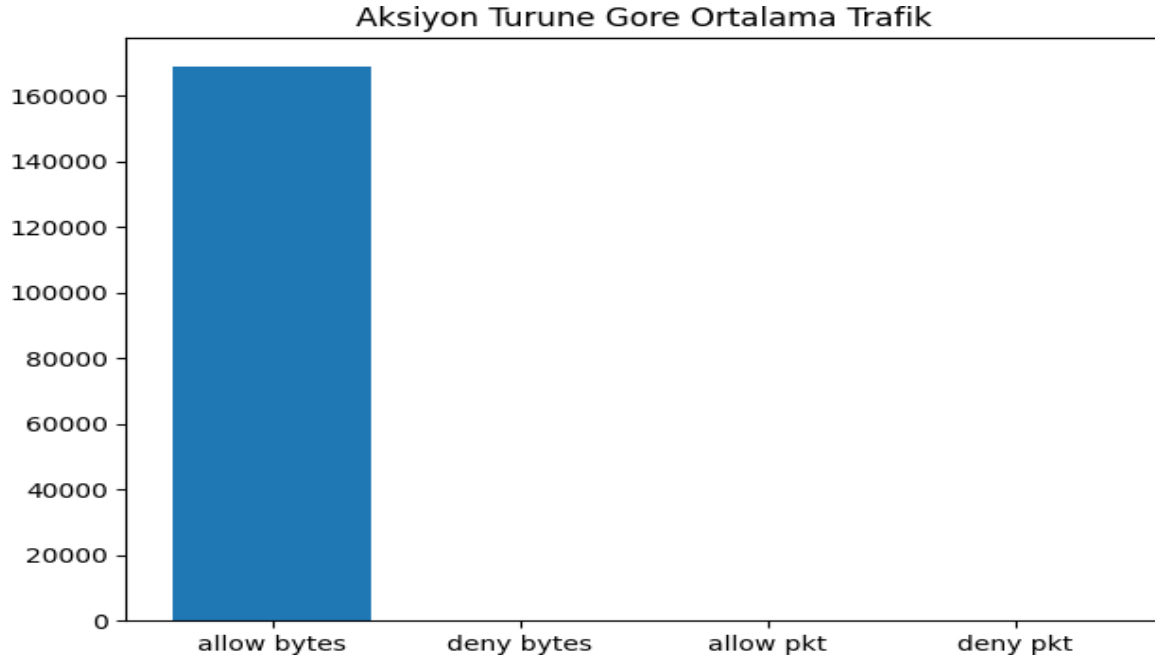
Şentürk ve Irmak (2024), kurumsal ağ ortamında VLAN segmentasyonu ile ACL kurallarının birlikte kullanılmasına rağmen servis düzeyindeki yanlış yapılandırma ve izin servisi yetki hatalarının bu ağ katmanını korumasını işlevsiz bırakabildiğini göstermektedir. Benzer biçimde Kanmaz (2023), SSRF saldırıları bağlamında ACL'nin tek başına bütün güvenlik mimarisini temsil etmediğini belirtmektedir. ACL bir savunma bileşenidir; fakat kural mantığı doğru kurulmadan katmanlama tek başına anlam ifade etmez.

Tespit Yönelik Yaklaşımlar

Ceylan ve Kavut (2025), OWASP, NIST, PTES, OSSTMM ve ISSAF metodolojilerini karşılaştırmalı olarak ele almaktadır. Hangi metodolojinin hangi saldırı tipine karşı daha etkili olduğunun bilinmesi, zafiyet tespit sürecini doğrudan etkilemektedir. Of (2019) ise periyodik güvenlik testlerine ek olarak OpenSMM ve BSIMM gibi olgunluk modellerinin erişim kontrol kalitesini ölçmede kullanılabileceğini belirtmektedir.

Veri seti üzerinde aksiyon türüne göre ortalama trafik metrikleri incelendiğinde allow kategorisindeki bağlantıların ortalama 169 KB veri ve 178 paket ürettiği; deny ve drop kategorilerinin ise çoğu zaman ilk pakette kesildiği görülmektedir. Bu durum ACL kurallarının erken aşamada devreye girdiğini gösterirken aynı zamanda sistemin yoğun bir filtreleme yükü altında çalıştığını ortaya koymaktadır. Dolayısıyla yalnızca kural yazmak değil, bu kuralların log analizi ile sürekli test edilmesi de gerekir.

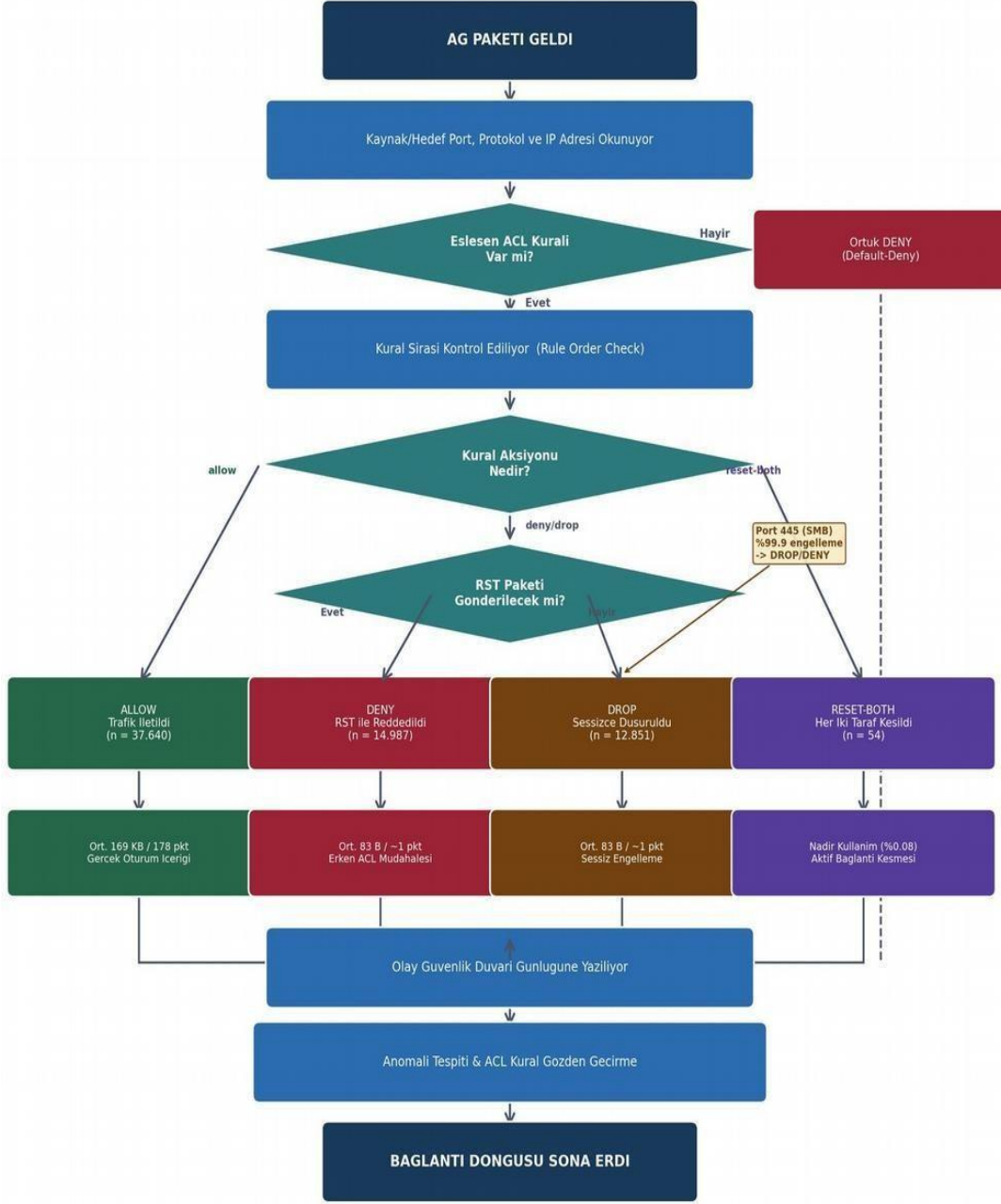
Şekil 4. Action türüne göre ortalama byte ve paket metrikleri.



Akış Şeması

ACL Güvenlik Duvarı Karar Akis Semasi

Kaggle Internet Firewall Data Set — 65.532 Baglantı Kaydı Referans Alınmıştır



Veri Seti: Kaggle — Internet Firewall Data Set
Toplam: 65.532 kayıt | allow: 37.640 (%57.4) | deny: 14.987 (%22.9) | drop: 12.851 (%19.6) | reset-both: 54 (%0.08)

Genel Değerlendirme

İncelediğim dört çalışmada birbiriyle örtüşen bazı çıkarımlar var. ACL tasarım hatalarının büyük çoğunluğu kasıtlı ihmalden değil, varsayılan ayarlara güvenmekten ya da zaman içinde kimin hangi yetkiye sahip olduğunun takibinin kaybedilmesinden geliyor. Ceylan ve Kavut (2025)'un belgelediği Apache banner açığı da Şentürk ve Irmak (2024)'ın bulduğu Generic All yetkisi de bu türden birikim hatalarının ürünü.

Kaggle veri setinden elde edilen bulgular da bu akademik tespiti destekliyor: %42.5 genel engelleme oranı, port 445 üzerinde %99.9 baskılama ve deny kayıtlarının çok düşük byte değerleri ACL kurallarının sürekli olarak sorunlu veya şüpheli trafiğe müdahale ettiğini gösteriyor. Fakat burada dikkat çeken nokta, iyi ACL'nin görünmez olması gerekirken kötü ACL'nin loglarda kendini fazla belli etmesidir.

En az ayrıcalık ilkesi, ağ ve sistem güvenliğinde tekrar tekrar vurgulanan ama uygulamada tutarsız kalan bir standart olmaya devam ediyor. Bozan ve Uzun (2023), güvenli bir sistemin üç temel koşulu olduğunu belirtiyor: her hassas işlemin erişim kontrolüne tabi tutulması, bu kontrolün yetkisiz varlıklar tarafından değiştirilememesi ve sistemin doğrulanabilir olması. Bu üçünden herhangi biri sağlanmadığında, ne kadar iyi tasarlanmış görünürse görünsün ACL yapısı fiilen devre dışı bırakılmış demektir.

Veri Seti Hakkında

<u>Dataset Adı</u>	Internet Firewall <u>Data Set</u>
<u>Kaynak</u>	<u>Kaggle (tunguz/internet-firewall-data-set)</u>
<u>Toplam Kayıt</u>	65.532 bağlantı kaydı
<u>Değişken Sayısı</u>	12 özellik (<u>Source/Dest Port, Action, Bytes, Packets vb.</u>)
<u>Kapsam</u>	Gerçek bir kurumsal güvenlik duvarından alınan ağ trafiği
<u>Hedef Değişken</u>	<u>Action: allow / deny / drop / reset-both</u>
<u>ACL İlgisi</u>	Her kayıt bir <u>ACL</u> kural kararını temsil etmektedir

Veri Seti Analizi — Özet Bulgular

Bulgu	ACL Tasarım Etkisi
%42.5 engelleme oranı	Ağa yönelik sürekli yetkisiz erişim baskısını gösteriyor
Port 445 -> %99.9 engel	Aşırı kısıtlayıcı ACL kuralı; meşru SMB trafiği etkilenmiş olabilir
deny ortalama 83 B	ACL kuralları çok erken devreye giriyor
allow -> 169 KB / 178 pkt	Geçen trafik gerçek oturum içeriğine sahip
reset-both 54 kayıt	Aktif bağlantı kesmesi nadiren Uygulanmış

Kaynakça

- Bozan, Y. S. ve Uzun, S. (2023). İşletim Sistemi Güvenliği. İçinde İ. Avcı ve M. Koca (Ed.), Bilgi ve Bilişim Sistemleri Güvenliği (ss. 41-51). Nobel Akademik Yayıncılık.
- Ceylan, M. F. ve Kavut, S. (2025). Sızma Denemeleri: Ölçünler, Süreçler ve Kandırma Teknikleri Üzerine Bir İnceleme. Bilgisayar Bilimleri ve Mühendisliği Dergisi, 18(1), 64- 85.
- Kanmaz, M. (2023). Web Uygulama Güvenliği. İçinde İ. Avcı ve M. Koca (Ed.), Bilgi ve Bilişim Sistemleri Güvenliği (ss. 53-71). Nobel Akademik Yayıncılık.
- Of, M. (2019). Siber Güvenlik Üzerine Bir Araştırma: Yazılım Güvenliği. Bayburt Üniversitesi Fen Bilimleri Dergisi, 2(2), 254-260.
- Şentürk, Z. ve Irmak, E. (2024). Windows Aktif Dizin Etki Alanı Servisi ve Kurumsal Ağ Güvenliği: PowerShell Erişiminin Analizi ve Önlemler. Gazi Üniversitesi Fen Bilimleri Dergisi Part C: Tasarım ve Teknoloji, 12(3), 475-487.